

Die 15 häufigsten KI-Fragen (2026)

Kompakt erklärt für Unternehmen | esperit IT-Beratung | Stand: 2026

esperit IT-Beratung
info@esperit.net

Dieser Guide beantwortet 15 Fragen, die im Unternehmensalltag besonders häufig zu Künstlicher Intelligenz gestellt werden – kompakt, verständlich und praxisnah. Die Fragen sind in vier thematische Cluster gegliedert: Sicherheit & Datenschutz, Recht & Regulatorik, Anwendbarkeit & Nutzen, Technologie-Grundlagen.

Cluster A – Sicherheit & Datenschutz

1. Welche konkreten Schutzmaßnahmen brauche ich, bevor KI-Tools auf Unternehmensdaten zugreifen?

Sechs Bereiche, in denen technisch etwas eingerichtet werden muss – nicht organisatorisch beschlossen:

- **Netzwerkebene:** Über Firewall oder Web-Proxy eine Positivliste freigegebener KI-Dienste definieren, alle übrigen sperren – inklusive der zugehörigen API-Endpunkte.
- **Datenbankebene:** Zugriff nur über Sichten (Views) mit den fachlich nötigen Spalten und Zeilen, Schreibrechte nur wo zwingend nötig.
- **Dateiebene:** Ein eigenes Freigabeverzeichnis statt Zugriff auf gewachsene Laufwerksstrukturen.
- **Datenebene:** Personenbezogene und sicherheitskritische Felder vor Übergabe an externe Modelle maskieren oder pseudonymisieren.
- **Zugangsdaten:** Eigener technischer Benutzer und eigener API-Schlüssel je Integration, Ablage im Secret-Speicher statt in Skripten.
- **Modelleinstellungen:** Trainingsnutzung deaktivieren, Aufbewahrungsdauer minimieren, Adminrechte auf wenige Personen begrenzen.

Diese Punkte sind in wenigen Tagen umsetzbar und wirken unabhängig davon, wie sich die Bedrohungslage entwickelt.

2. Meine Mitarbeitenden nutzen KI-Tools, die ich nie freigegeben habe – was tue ich?

Das Verhalten ist normal und meist gut gemeint. Das Risiko entsteht nicht durch die Nutzung, sondern dadurch, dass niemand weiß, welche Daten in welches System fließen.

Reihenfolge, die sich in der Praxis bewährt:

1. **Sichtbar machen:** Proxy- oder Firewall-Protokolle der letzten vier Wochen auf Zugriffe zu bekannten KI-Diensten auswerten.
2. **Ersatz anbieten, bevor gesperrt wird:** Freigegebene Alternative mit Auftragsverarbeitungsvertrag und deaktiviertem Training bereitstellen.
3. **Technisch begrenzen:** Nicht freigegebene Dienste über den Proxy sperren, Datei-Upload in nicht freigegebene Browserfenster verhindern.
4. **Verbindlich regeln:** Kurze Nutzungsrichtlinie, die konkret benennt, welche Datenkategorien nie in ein externes KI-System dürfen.
5. **Beim Austritt entziehen:** KI-Berechtigungen gehören in die Offboarding-Checkliste.

3. Wie verhindere ich, dass meine Eingaben zum Training fremder KI-Modelle verwendet werden?

In den meisten kommerziellen KI-Tools lässt sich das Trainings-Opt-out in den Konto- oder Admin-Einstellungen aktivieren – bei Business- und Enterprise-Tarifen häufig standardmäßig deaktiviert, bei kostenlosen Consumer-Zugängen dagegen oft aktiv.

Wichtig ist die Unterscheidung zwischen Trainingsnutzung und Verarbeitung: Auch ohne Training verarbeitet der Anbieter Eingaben zur Beantwortung – auf Servern, deren Standort und Sicherheitsniveau je nach Anbieter variieren.

Wer volle Kontrolle braucht, kommt an zwei Punkten nicht vorbei: einem Auftragsverarbeitungsvertrag mit dem Anbieter und – bei besonders sensiblen Daten – der Prüfung, ob ein lokal betriebenes Modell die bessere Lösung ist.

4. Wie schütze ich mich vor Prompt-Injection-Angriffen auf meine KI-Systeme?

Prompt-Injection bezeichnet den Versuch, ein KI-System über manipulierte Eingaben – etwa in einem Dokument, einer E-Mail oder einer Webseite, die ein Agent liest – zu unbeabsichtigtem Verhalten zu bewegen. Besonders kritisch, sobald ein Agent Aktionen mit echten Systemzugriffen ausführt.

- **Rechteebene:** Geringstmögliche Berechtigung – ein manipulierter Agent kann nur das anrichten, wozu sein Zugang reicht.
- **Trennung von Anweisung und Inhalt:** Externe Eingaben technisch als „zu verarbeitender Inhalt“ kennzeichnen, nicht als Anweisung.
- **Freigabeschritt vor kritischen Aktionen:** Finanzielle, rechtliche oder nach außen wirkende Aktionen durchlaufen immer einen Freigabeschritt.
- **Eingrenzung der Werkzeuge:** Ein Lese-Agent bekommt keinen Zugriff auf E-Mail-Versand oder Zahlungsauslösung.
- **Protokollierung:** Auffällige Abweichungen nur erkennbar, wenn das Journal regelmäßig eingesehen wird.

Ein hundertprozentiger Schutz existiert nach heutigem Stand nicht – Ziel ist, den möglichen Schaden zu begrenzen.

5. Gilt der EU AI Act jetzt schon für mein Unternehmen, oder wurden die Fristen verschoben?

Teilweise verschoben, teilweise nicht. Am 27. Juli 2026 trat die Änderungsverordnung „Digital Omnibus“ (EU 2026/1744) in Kraft und verschob die vollständigen Pflichten für Hochrisiko-KI-Systeme (Anhang III) vom 2. August 2026 auf den 2. Dezember 2027.

Nicht verschoben wurden die Transparenzpflichten nach Artikel 50: Wer einen Chatbot betreibt oder KI-generierte Inhalte veröffentlicht, muss dies seit dem 2. August 2026 kennzeichnen.

Für die meisten Mittelstandsunternehmen ohne Hochrisiko-Anwendung heißt das: Die Kennzeichnungspflicht betrifft Sie schon jetzt, die Hochrisiko-Pflichten erst später.

6. Welche Bußgelder drohen bei Verstößen gegen den EU AI Act?

Verbotene KI-Praktiken (Artikel 5) werden mit bis zu 35 Millionen Euro oder 7 Prozent des weltweiten Jahresumsatzes geahndet. Verstöße gegen Hochrisiko- oder Betreiberpflichten liegen bei bis zu 15 Millionen Euro oder 3 Prozent, Falschangaben gegenüber Behörden bei bis zu 7,5 Millionen Euro oder 1 Prozent.

Die meisten Mittelstandsanwendungen – Chatbots, interne Assistenten, Textgenerierung – fallen nicht unter die Hochrisiko-Kategorie. Die Kennzeichnungspflicht nach Artikel 50 bleibt aber für praktisch jedes Unternehmen mit KI-Einsatz relevant.

7. Muss ich KI-generierte Inhalte auf meiner Website kennzeichnen?

Ja, seit dem 2. August 2026 gilt die Kennzeichnungspflicht nach Artikel 50 EU AI Act für synthetische Inhalte wie KI-generierte Texte, Bilder, Videos oder Audiodateien – unabhängig von der Unternehmensgröße.

Für Text- und Chatbot-Anwendungen reicht in der Praxis meist ein klarer Hinweis, dass Inhalte mithilfe von KI erstellt wurden.

8. Brauche ich für ChatGPT, Copilot & Co. einen Auftragsverarbeitungsvertrag?

In aller Regel ja, sobald personenbezogene Daten im Spiel sind – etwa Kundennamen in einem Support-Chatbot oder Bewerberdaten in einem HR-Tool. Business- und Enterprise-Tarife stellen einen Auftragsverarbeitungsvertrag meist standardmäßig bereit, kostenlose Consumer-Zugänge in der Regel nicht.

Ein Auftragsverarbeitungsvertrag regelt die vertragliche Verantwortung, ändert aber nichts daran, wohin Daten technisch fließen – bei US-Anbietern bleibt zusätzlich die Rechtsgrundlage der Datenübermittlung relevant.

9. Welche KI-Anwendungen bringen unabhängig von der Branche den größten Hebel?

Drei Kategorien wiederholen sich über nahezu alle Branchen hinweg: Wissensarbeit auf verstreuten internen Dokumenten (RAG-gestützter Assistent), strukturierte Texterstellung mit hohem Wiederholungsanteil sowie Recherche- und Analyseaufgaben, bei denen ein KI-Entwurf den Startpunkt beschleunigt.

Der gemeinsame Nenner: Diese drei reduzieren einen Engpass, den fast jedes Unternehmen hat – unabhängig von Abteilung oder Branche.

10. Brauche ich für jede Aufgabe ein eigenes KI-Tool, oder gibt es eine Komplettlösung?

Eine Universallösung gibt es nicht, aber drei Schichten tragen den Großteil des Bedarfs: eine Sprachmodell-Plattform für Text, Analyse und Recherche; die KI-Funktionen bereits vorhandener Software (ERP, CRM, Buchhaltung); eine Automatisierungsplattform, die Systeme verbindet.

Spezialwerkzeuge lohnen sich erst bei hohem Volumen und klarer Schwäche der Allzwecklösung. Praktikable Gegenmaßnahme gegen Abhängigkeit: Systemverbindungen in einer austauschbaren Zwischenschicht statt direkt im Tool aufbauen.

11. Wie deckele ich den Tokenverbrauch und begrenze ihn je Mitarbeiter?

- **Nutzer-Abos:** Feste Monatsgebühr, Kostenrisiko gleich null, aber kein Einfluss auf die Nutzungsmenge.
- **Schnittstellenzugriff (API):** Monatsbudgets je Projekt und Schlüssel, Warnschwellen und Ratenlimits setzen. Je Abteilung ein eigener Schlüssel mit eigenem Budget.
- **Automatisierte Abläufe:** Größter unbemerkter Kostentreiber. Maximale Durchlaufzahl begrenzen, Wiederholungsversuche bei Fehlern auf zwei bis drei beschränken.

Weitere Hebel: kleineres Modell für einfache Aufgaben, nur benötigte Dokumente übergeben, Zwischenspeicherung (Caching) wiederkehrender Anweisungsteile nutzen.

12. Gibt es eine Plattform, über die ich mehrere Sprachmodelle nutzen kann, ohne für jedes ein eigenes Abo abzuschließen?

- **Aggregatoren** (Beispiele: OpenRouter, LiteLLM): Bündeln den Zugriff auf Dutzende Modelle über einen Zugangsschlüssel. Gedacht für die technische Anbindung, ohne Nutzerverwaltung.
- **Europäische Unternehmensplattformen** (Beispiele: Langdock, InnoGPT): Einheitliche Oberfläche mit Nutzerverwaltung, Rechtevergabe und Auftragsverarbeitungsvertrag – für DSGVO-sensible Umgebungen meist der passendste Weg.
- **Eigener Betrieb** (Beispiele: Open WebUI, Ollama): Selbst betriebene Oberfläche mit lokal laufenden offenen Modellen. Höchste Kontrolle, dafür Betriebsaufwand.

Für den Mittelstand ist die europäische Unternehmensplattform meist der beste Kompromiss.

13. Was ist ein KI-Agent, und was kann er anders als ein Chatbot?

Ein klassischer Chatbot beantwortet Fragen und liefert Text – ein KI-Agent führt eigenständig mehrere Arbeitsschritte aus: Informationen zusammentragen, Werkzeuge aufrufen, Zwischenergebnisse bewerten, nächste Schritte selbst planen.

Der Praxisnutzen steigt mit der Selbstständigkeit, aber auch das Risiko: Ein Agent braucht klar begrenzte Zugriffsrechte und eine nachvollziehbare Protokollierung.

14. Wo richte ich einen KI-Agenten ein, und welche Zugänge braucht er?

Zwei übliche Orte: direkt beim Sprachmodell-Anbieter (schnell, gut für Text und Dokumente) oder in einer Automatisierungsplattform wie Make oder n8n (üblich, wenn mehrere Systeme zusammenspielen).

Die Zugänge entstehen in dieser Vorzugsreihenfolge:

1. **Schnittstelle des Zielsystems (API):** Eigener technischer Benutzer mit Rechten genau für die jeweilige Aufgabe.
2. **Model Context Protocol (MCP):** Standardisiertes Verbindungsprotokoll, Rechtevergabe an einer Stelle gebündelt.
3. **Datenbanksicht mit Lesezugriff** oder als letzte Wahl Oberflächenautomatisierung bei Altsystemen.

Zwei feste Regeln: Kein Agent nutzt den Zugang eines Menschen, und jede Aktion mit finanzieller oder rechtlicher Wirkung erhält einen Freigabeschritt.

15. Wie kontrolliere ich, was ein KI-Agent tatsächlich getan hat?

Nicht über den Agenten selbst – die Kontrolle muss an Stellen ansetzen, die der Agent nicht verändern kann:

- **Ausführungsprotokoll der Automatisierungsplattform:** Zeitstempel, Eingangsdaten, aufgerufene Systeme, Ergebnis.
- **Protokoll im Zielsystem:** Eigener technischer Benutzer macht Buchungen im ERP oder in der Buchhaltung nach Benutzer filterbar – die revisionssichere Spur.
- **Fachliches Journal:** Ein Workflow-Baustein schreibt Datum, Vorgang, Belegnummer und Entscheidung aus den tatsächlichen Werten – nicht aus einer Modellzusammenfassung.

Für die Human-in-the-Loop-Kontrolle: Aktionen mit Außenwirkung erzeugen einen Freigabeeintrag, etwa per Teams- oder Slack-Nachricht mit Freigabe-Schaltfläche, bevor sie ausgeführt werden.

Kostenloses KI-Erstgespräch (30 Min.)

Sie haben weitere Fragen zu KI in Ihrem Unternehmen – oder möchten wissen, welche Möglichkeiten konkret für Sie relevant sind? Sprechen wir darüber.

E-Mail: info@esperit.net | Telefon: +49 177 2578260